

Acme Corp - Nexus Integration Hub

Acme Corp - Nexus Integration Hub

Authentication & Identity Guide

Overview

The Nexus Integration Hub uses OAuth 2.0 with JWT bearer tokens for all API authentication.

Enterprise clients authenticate via SAML 2.0 SSO federated to our OAuth provider.

Every client request must include a valid OAuth access token obtained through the authorization code flow.

Configuration

Set the following environment variables:

`OAUTH_CLIENT_ID=your-client-id`

`OAUTH_CLIENT_SECRET=your-client-secret`

`OAUTH_TOKEN_URL=https://auth.nexus.acme-corp.example.com/oauth/token`

`OAUTH_SCOPES=read,write,admin`

`SAML_IDP_METADATA_URL=https://sso.acme-corp.example.com/metadata`

Token Validation

The API gateway validates tokens on every request:

1. Extract bearer token from Authorization header
2. Verify JWT signature against the OAuth provider JWKS endpoint
3. Check token expiry and required scopes
4. Map OAuth sub claim to internal enterprise user ID

Supported Grant Types

Authorization Code — Active — Web applications and enterprise SSO

Client Credentials — Active — Service-to-service integrations

Resource Owner Password — Deprecated — Legacy only, do not use

API Key (header) — Not supported — N/A

Security Requirements

- Tokens must expire within 1 hour
- Refresh tokens rotate on every use
- All OAuth endpoints require TLS 1.2+
- Rate limiting: 100 token requests per minute per client
- SOC 2 Type II audit logging on all auth events

Migration Notes

The platform team evaluated API key authentication in Q3 2024 but decided to retain OAuth 2.0 and SAML SSO as the sole authentication mechanisms. API keys were deemed insufficient for Acme Corp multi-tenant audit and compliance requirements.